

Attacking FTP

The [File Transfer Protocol \(FTP\)](#) is a standard network protocol used to transfer files between computers. It supports various file operations, such as changing the working directory, listing files, and renaming and deleting directories. FTP typically runs on port [TCP/21](#).

To attack an FTP Server, we can abuse misconfiguration or excessive privileges, exploit known vulnerabilities, or use the service's inherent vulnerabilities. Therefore, after gaining access to the FTP Service, we need to be aware of the content in the directory for sensitive or critical information, as we previously discussed. The protocol is designed to trigger download and upload commands. Thus, files can be transferred between servers and clients. A file management system is available on the operating system. Files can be stored in folders, which may be located in other folders. This results in a hierarchical structure. Most companies use this service for software or website development processes.

Enumeration

[Nmap](#) default scripts [-sC](#) includes the [ftp-anon](#) Nmap script which checks if a FTP server allows anonymous access. The [-sV](#) enumeration flag provides interesting information about FTP services, such as the FTP banner, which is the server's name. We can use the [ftp](#) client or [nc](#) to interact with the FTP service. By default, FTP runs on TCP port 21.

Nmap

Attacking FTP

```
dbcyph0n@htb[/htb]$ sudo nmap -sC -sV -p 21 192.168.2.142
```

```
Starting Nmap 7.91 ( https://nmap.org ) at 2021-08-10 22:04 EDT
Nmap scan report for 192.168.2.142
Host is up (0.00054s latency).
```

PORT	STATE	SERVICE
21/tcp	open	ftp
ftp-anon: Anonymous FTP login allowed (FTP code 230)		
-rw-r--r--	1 1170	924 31 Mar 28 2001 .banner
d--x--x--x	2 root	root 1024 Jan 14 2002 bin
d--x--x--x	2 root	root 1024 Aug 10 1999 etc

Attacking FTP

```
dbcyph0n@htb[/htb]$ ftp 192.168.2.142

Connected to 192.168.2.142.
220 (vsFTPd 2.3.4)
Name (192.168.2.142:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-r--r--    1 0          0          9 Aug 12 16:51 test.txt
226 Directory send OK.
```

Once we get access to an FTP server with anonymous credentials, we can start searching for interesting commands `ls` and `cd` to move around directories like in Linux. To download a single file, we use `get`, and we can use `mget`. For upload operations, we can use `put` for a simple file or `mput` for multiple files. We can use `help` for more information.

In the [Footprinting](#) module, we cover detailed information about possible misconfigurations of such services. Various settings can be applied to an FTP server, and some of them lead to different options that could cause possible vulnerabilities. However, this module will focus on specific attacks rather than finding individual misconfigurations.

Protocol Specifics Attacks

Many different attacks and methods are protocol-based. However, it is essential to note that we are not attacking the protocols themselves but the services that use them. Since there are dozens of services for a single protocol and they handle information differently, we will look at some.

Brute Forcing

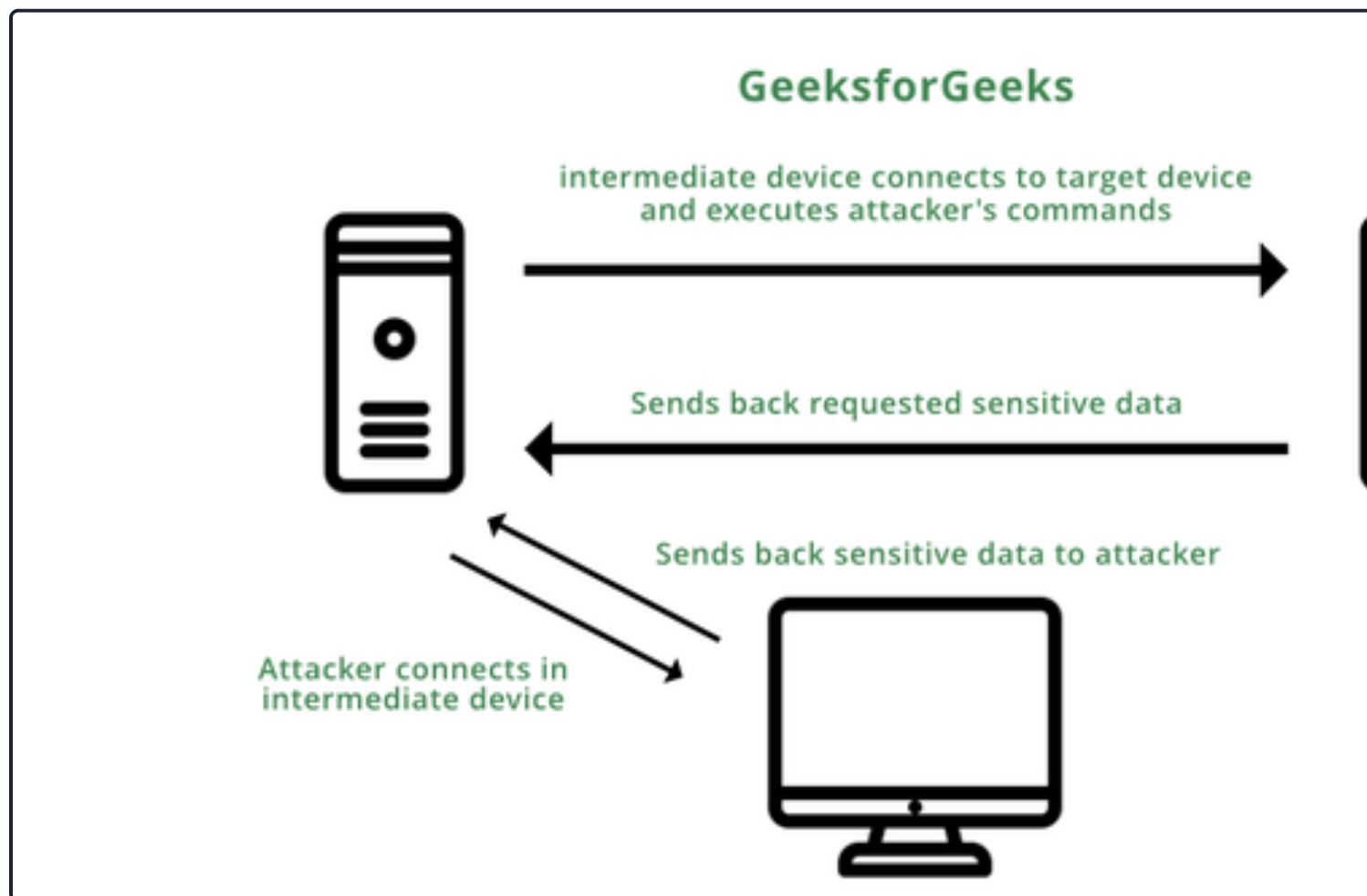
If there is no anonymous authentication available, we can also brute-force the login for the FTP services using usernames and passwords. There are many different tools to perform a brute-forcing attack. Let us explore

`Medusa`, we can use the option `-u` to specify a single user to target, or you can use the option `-U` to provide

The option `-P` is for a file containing a list of passwords. We can use the option `-M` and the protocol we are

An FTP bounce attack is a network attack that uses FTP servers to deliver outbound traffic to another device. The attacker uses a `PORT` command to trick the FTP connection into running commands and getting information from a target server.

Consider we are targetting an FTP Server `FTP_DMZ` exposed to the internet. Another device within the same network is also exposed to the internet. We can use the connection to the `FTP_DMZ` server to scan `Internal_DMZ` using the information about the server's open ports. Then, we can use that information as part of our attack against



Source: <https://www.geeksforgeeks.org/what-is-ftp-bounce-attack/>

The `Nmap -b` flag can be used to perform an FTP bounce attack:

Attacking FTP

```
dbcyph0n@htb[/htb]$ nmap -Pn -v -n -p80 -b anonymous:password@10.10.110.213 172.17.0.2
```

```
Starting Nmap 7.80 ( https://nmap.org ) at 2020-10-27 04:55 EDT
Resolved FTP bounce attack proxy to 10.10.110.213 (10.10.110.213).
Attempting connection to ftp://anonymous:password@10.10.110.213:21
Connected:220 (vsFTPd 3.0.3)
Login credentials accepted by FTP server!
Initiating Bounce Scan at 04:55
```

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

EU Academy 4

PROTOCOL

☒ UDP 1337 ☐ TCP 443

DOWNLOAD VPN CONNECTION FILE

Start Instance

∞ / 1 spawns left

+10 Streak pts

+ 1 

Use the discovered username with its password to login via SSH and obtain the flag.txt file. Submit your answer here...

Submit your answer here...

+10 Streak pts

[← Previous](#)[Next →](#) [Cheat Sheet](#) [Resources](#) [Go to Questions](#)

Table of Contents

Introduction

[Interacting with Common Services](#)

Protocol Specific Attacks

[The Concept of Attacks](#)[Service Misconfigurations](#)[Finding Sensitive Information](#)

FTP

 [Attacking FTP](#)[Latest FTP Vulnerabilities](#)

SMB

 [Attacking SMB](#)[Latest SMB Vulnerabilities](#)

Latest Email Service Vulnerabilities

Skills Assessment

-  Attacking Common Services - Easy
-  Attacking Common Services - Medium
-  Attacking Common Services - Hard

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left